

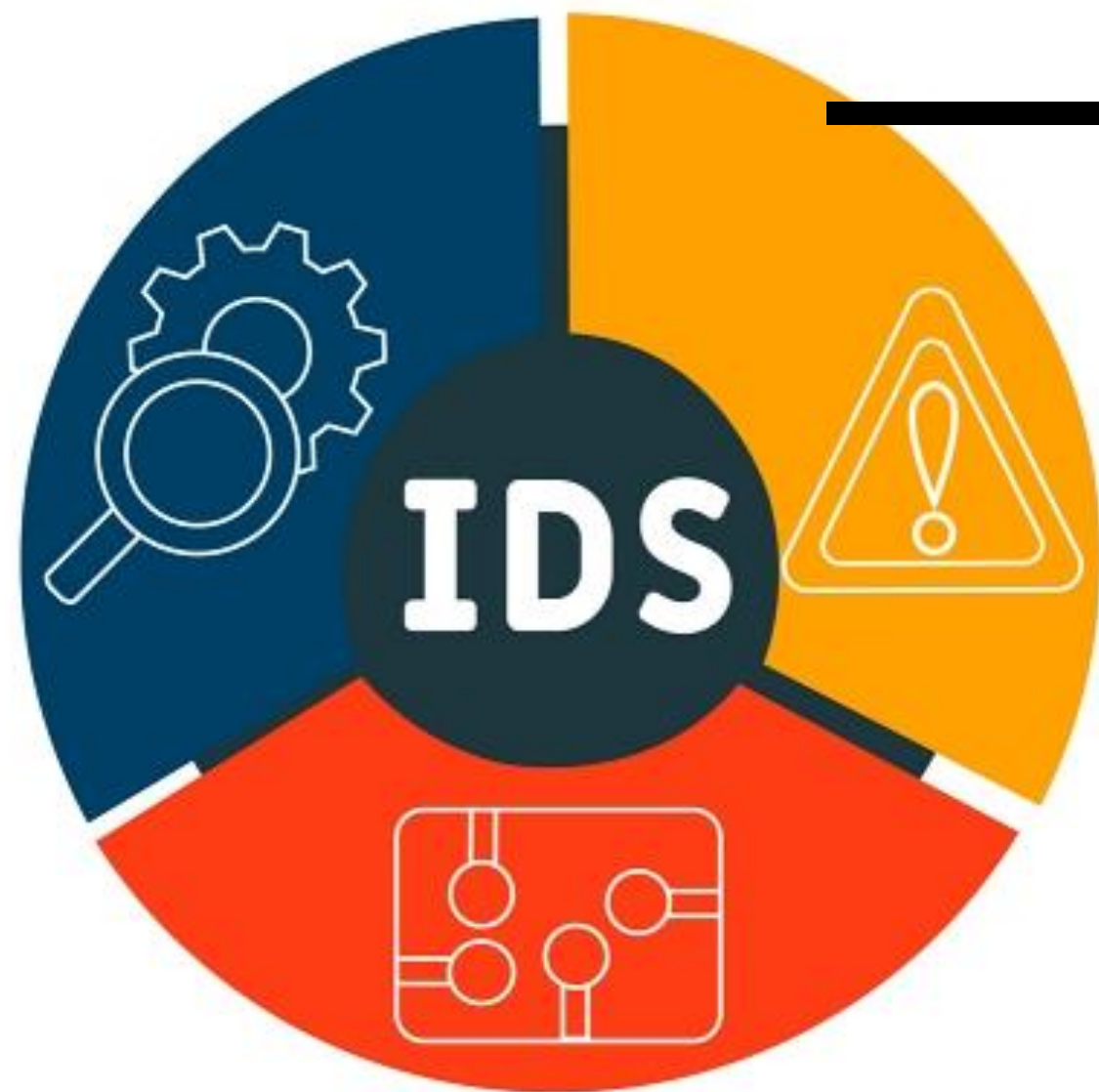
APT: Percorsi d'attacco

Definizione percorsi d'attacco e implementazione in Python



Obiettivo
della tesi

+



INTRUSION DETECTION SYSTEM

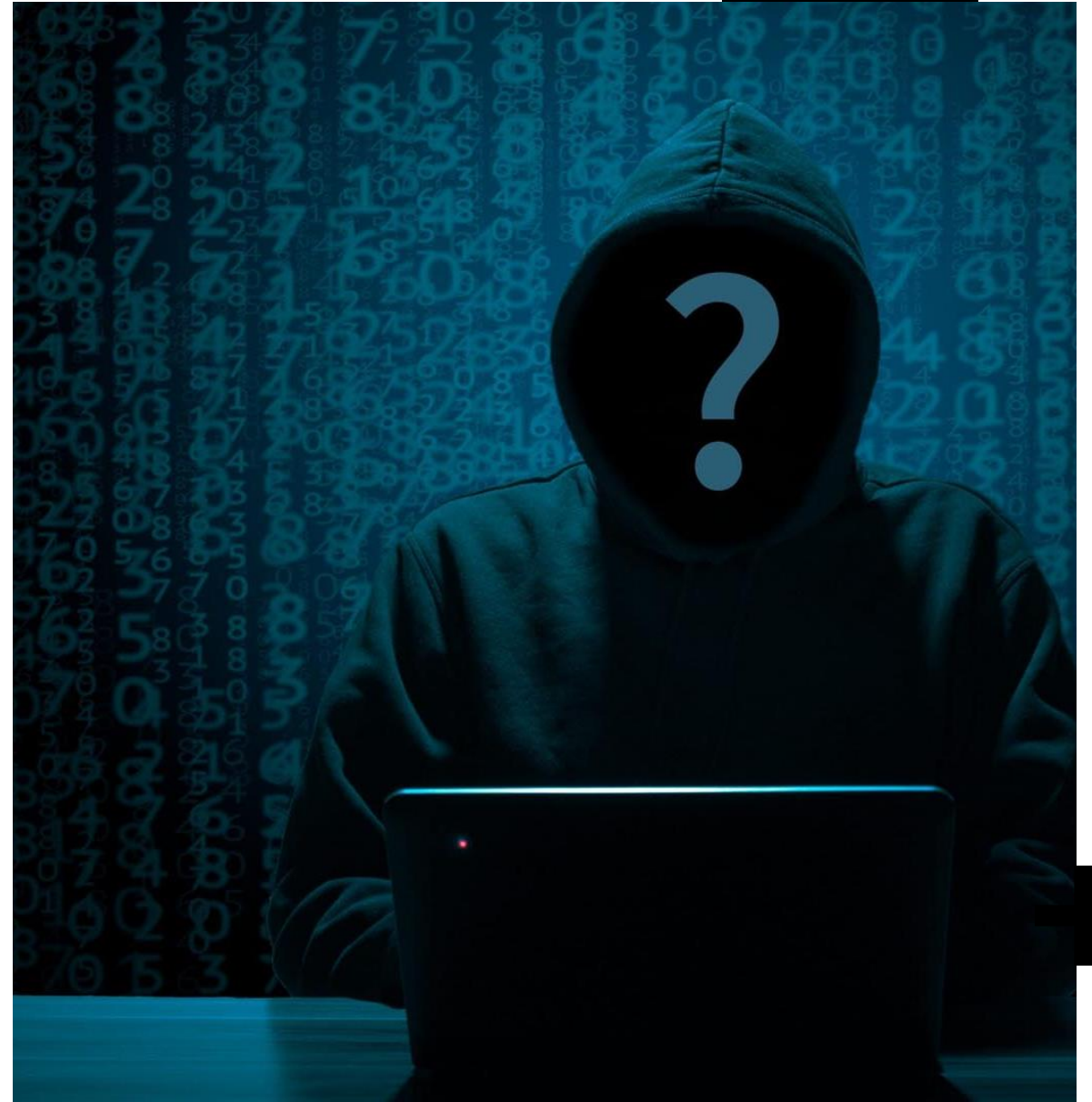
The background of the slide is a dark grey field filled with white binary code (0s and 1s) arranged in a perspective that creates a sense of depth. A prominent red starburst or explosion-like graphic is centered on the right side of the image, with its rays extending towards the center. The text 'Introduzione agli APT' is written in a large, white, sans-serif font on the left side of the image.

Introduzione agli APT



Caratteristiche APT

- Advanced
- Persistent
- Threat



Advanced

- Numerose tecniche e canali di raccolta dell'informazione
- Strumenti software e tecnologie per l'intrusione nel sistema
- Know-how per combinare tecniche e strumenti vecchi o per svilupparne di nuovi quando necessario per superare un ostacolo nell'attacco



Persistent

- Gli attaccanti hanno un obiettivo chiaro, ben definito
- Presenza di uno sponsor, che permette di avere attacchi a lungo termine
- Adottazione strategia low-and-slow, per diminuire la probabilità di essere scoperti e aumentare quella di successo

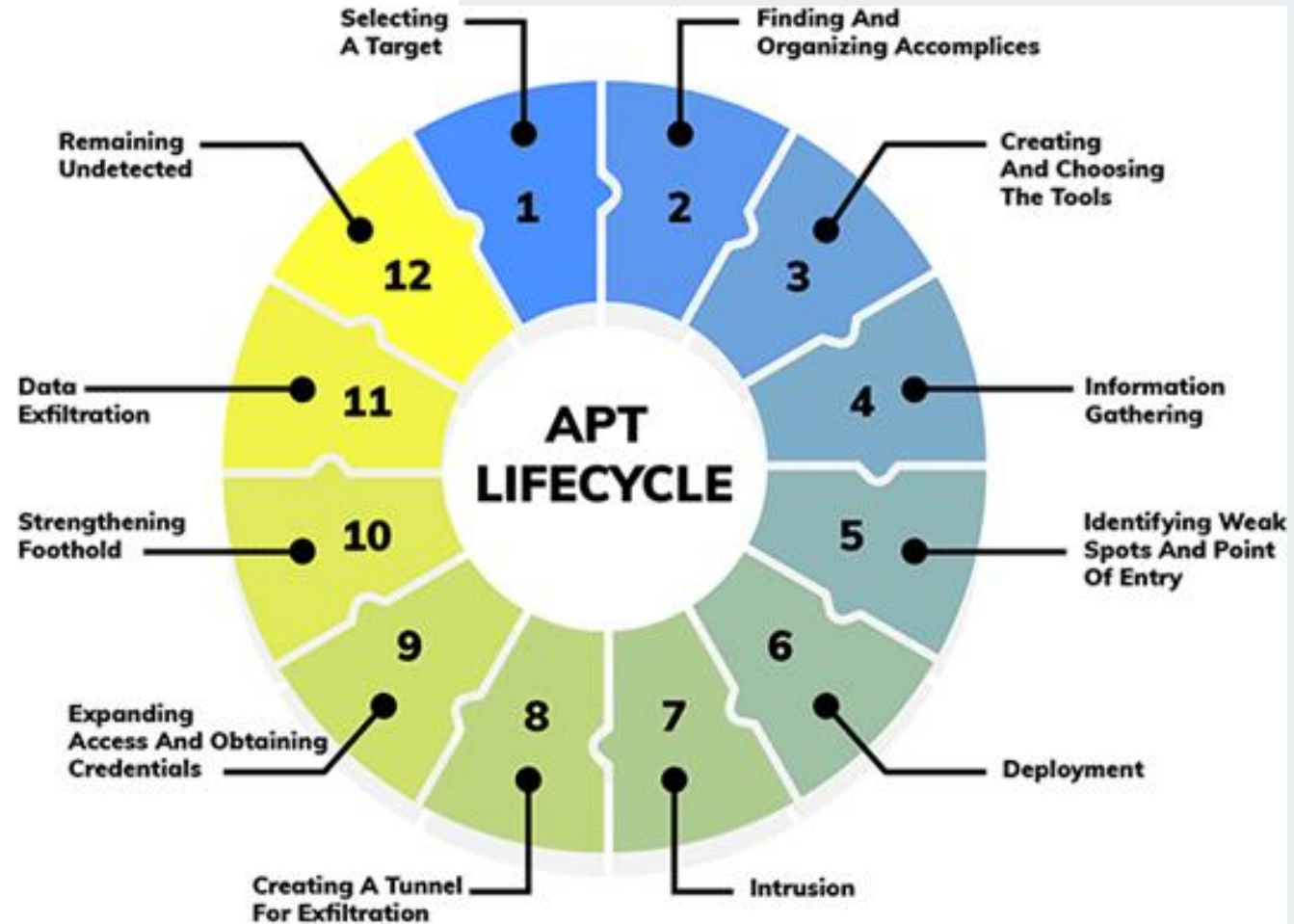


Threat

Gli APT sono pericolosi perché portano con sé un elevato rischio di perdita di dati sensibili o impedimento di componenti importanti nel sistema e perché sono molto difficili da rilevare e difendere dato le caratteristiche già citate

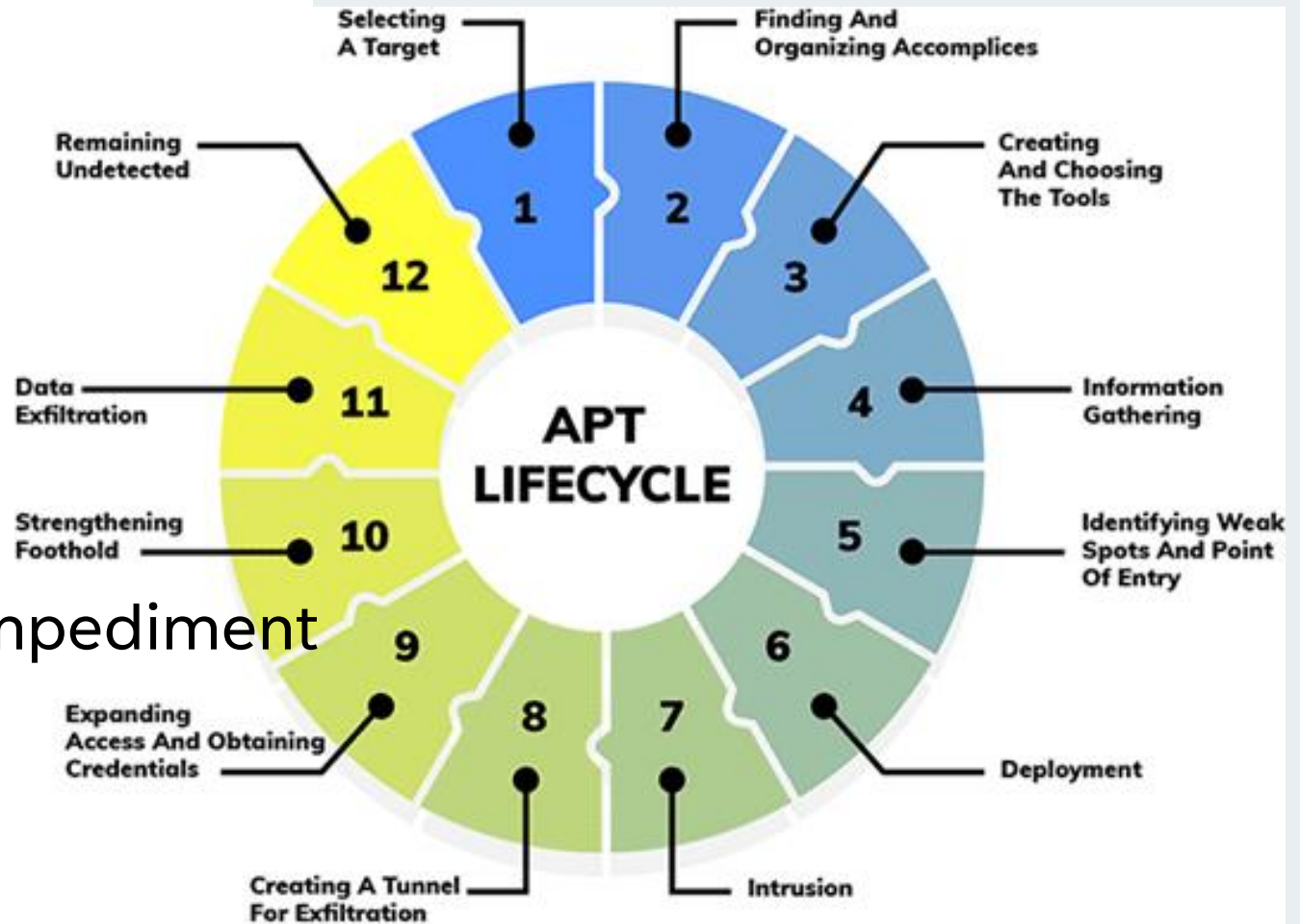


Fasi di un APT



Fasi di un APT

- Reconnaissance
- Establish Foothold
- Lateral Movement
- Exfiltration/Impediment
- Post-Exfiltration/Post-Impediment



Reconnaissance

Informazioni raccolte:

- Dettagli degli impiegati
- Informazioni sull'infrastruttura IT
- ...

Tecniche usate per raccogliere informazioni:

- Social engineering
- Port scanning
- Service scanning
- ...



Establish Foothold

Metodi e tecniche popolari usate dagli attaccanti in questa fase:

- Malware
- Sfruttamento di vulnerabilità note
- Spear-phishing
- Vulnerabilità Zero-day
- Attacchi Water-Hole
- ...



Lateral movement

L'obiettivo di questa fase è esplorare la rete o il sistema in cerca dei dati da esfiltrare o del componente da impedire. Anche in questo caso ci sono molte tecniche per permettere uno spostamento sicuro:

- Uso di credenziali rubati
- Installazione malware e altri strumenti sulle macchine
- Privelege escalation
- key loggers
- ...



Esfiltrazione / Impedimento e Post-Esfiltrazione / Post-Impedimento

Nelle ultime due fasi di un APT, gli attaccanti completano l'obiettivo dell'attacco e, a seconda delle indicazioni dallo sponsor, possono continuare l'operazione esfiltrando più dati e impedendo più componenti oppure passare all'eliminazione delle tracce dell'attacco.





MITRE
ATT&CKTM

The logo features the word "MITRE" in a bold, blue, sans-serif font, positioned above the word "ATT&CK" in a bold, red, sans-serif font. A small "TM" trademark symbol is located to the right of "ATT&CK". The text is centered on a white background, with a light blue rectangular area to its right and a black plus sign at the bottom right.

Tactics e Techniques

- Tactics -> Why
- Techniques -> How

Enterprise Matrix

Below are the tactics and techniques representing the MITRE ATT&CK® Matrix for Enterprise. The Matrix contains information for the following platforms: [Windows](#), [macOS](#), [Linux](#), [PRE](#), [Office Suite](#), [Identity Provider](#), [SaaS](#), [IaaS](#), [Network](#), [Containers](#).

[View on the ATT&CK® Navigator](#)



[Version Permalink](#)

layout: side ▼

show sub-techniques

hide sub-techniques

help

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Impact
10 techniques	8 techniques	10 techniques	14 techniques	20 techniques	14 techniques	44 techniques	17 techniques	10 techniques
Active Scanning (3)	Acquire Access	Content Injection	Cloud Administration Command	Account Manipulation (7)	Abuse Elevation Control Mechanism (6)	Abuse Elevation Control Mechanism (6)	Adversary-in-the-Middle (4)	Account Manipulation (7)
Gather Victim Host Information (4)	Acquire Infrastructure (8)	Drive-by Compromise	Command and Scripting Interpreter (11)	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (4)	Application Disruption (3)
Gather Victim Identity Information (3)	Compromise Accounts (3)	Exploit Public-Facing Application	Container Administration Command	Boot or Logon Autostart Execution (14)	Account Manipulation (7)	BITS Jobs	Credentials from Password Stores (6)	Browser Disruption (3)
Gather Victim Network Information (6)	Compromise Infrastructure (8)	External Remote Services	Deploy Container	Boot or Logon Initialization Scripts (5)	Boot or Logon Autostart Execution (14)	Build Image on Host	Exploitation for Credential Access	Cloud Disruption (3)
Gather Victim Org Information (4)	Develop Capabilities (4)	Hardware Additions	Exploitation for Client Execution	Browser Extensions	Boot or Logon Initialization Scripts (5)	Debugger Evasion	Forced Authentication	Cloud Dashboard Disruption (3)
Phishing for Information (4)	Establish Accounts (3)	Phishing (4)	Inter-Process Communication (3)	Compromise Host Software Binary		Deobfuscate/Decode Files or Information	Forge Web Credentials (2)	Cloud Disruption (3)
Search Closed	Obtain Capabilities (7)					Deploy Container		
						Direct Volume Access		



Esempio di Tactic e di Technique

Reconnaissance

The adversary is trying to gather information they can use to plan future operations.

Reconnaissance consists of techniques that involve adversaries actively or passively gathering information that can be used to support targeting. Such information may include details of the victim organization, infrastructure, or staff/personnel. This information can be leveraged by the adversary to aid in other phases of the adversary lifecycle, such as using gathered information to plan and execute Initial Access, to scope and prioritize post-compromise objectives, or to drive and lead further Reconnaissance efforts.

ID: TA0043

Created: 02 October 2020

Last Modified: 18 October 2020

[Version](#) [Permalink](#)

Techniques

Techniques: 10

ID	Name	Description
T1595	Active Scanning	Adversaries may execute active reconnaissance scans to gather information that can be used during targeting. Active scans are those where the adversary probes victim infrastructure via network traffic, as opposed to other forms of reconnaissance that do not involve direct interaction.



Sistema CVE

Fornisce un metodo semplice per la ricerca, identificazione e riferimento di vulnerabilità ed esposizioni pubbliche attraverso l'uso delle CVE-ID



Esempio di elemento nel database CVE

CVE-2018-5000

PUBLISHED

[View JSON](#) | [User Guide](#)

Collapse all

Required CVE Record Information

CNA: Adobe Systems Incorporated

Published: 2018-07-09 Updated: 2018-10-21

Description

Adobe Flash Player

 versions 29.0.0.171 and earlier have an Integer Overflow vulnerability. Successful exploitation could lead to information disclosure.

Product Status

[Learn more](#)

Vendor	Product
n/a	Adobe Flash Player 29.0.0.171 and earlier versions

Versions

1 Total



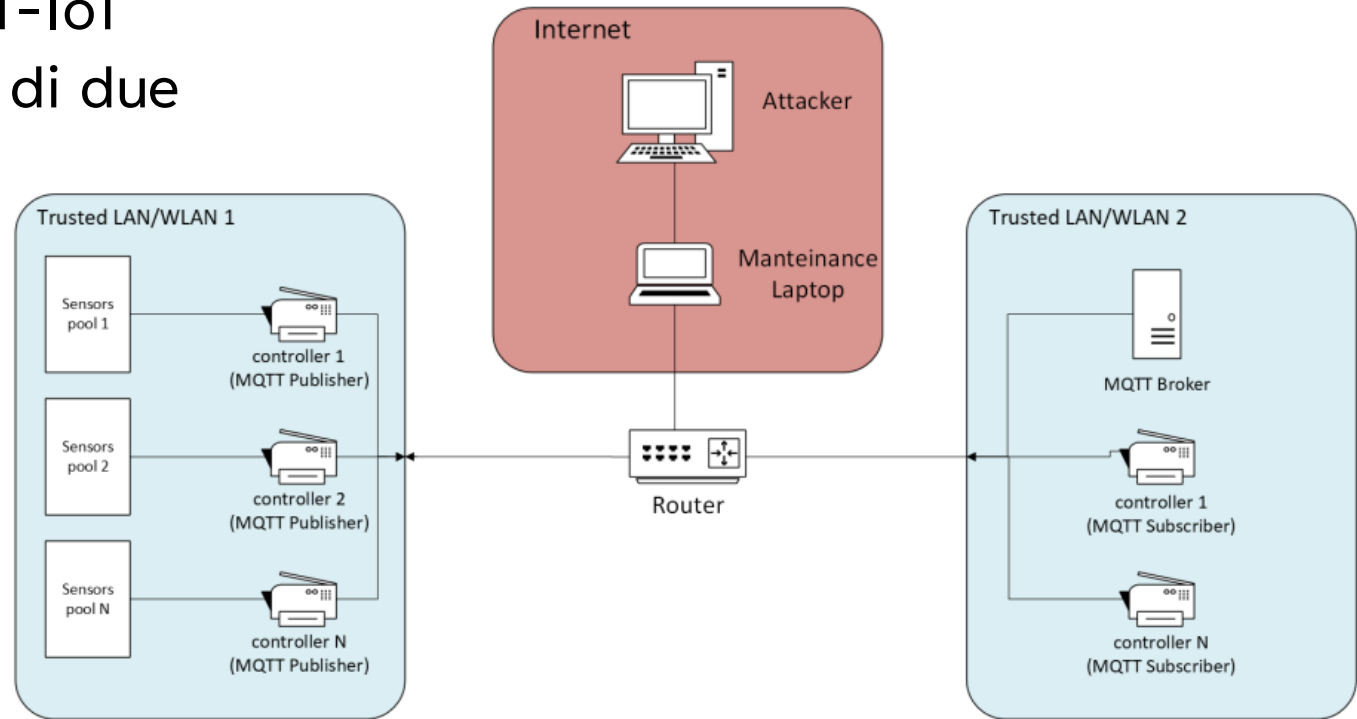
Protocollo MQTT

- Protocollo leggero a livello di applicazione
- Strategia publish-subscribe
- Richiede un livello di trasporto tipicamente fornito dalla suite di protocolli TCP/IP
- Usato nei sistemi come IoT dove ci sono restrizioni sulla banda di rete o sulle risorse



Topologia rete sottoposta agli attacchi

Abbiamo una topologia MQTT-IoT semplificata, con la presenza di due sottoreti:



DDoShield-IoT e topologia effettiva

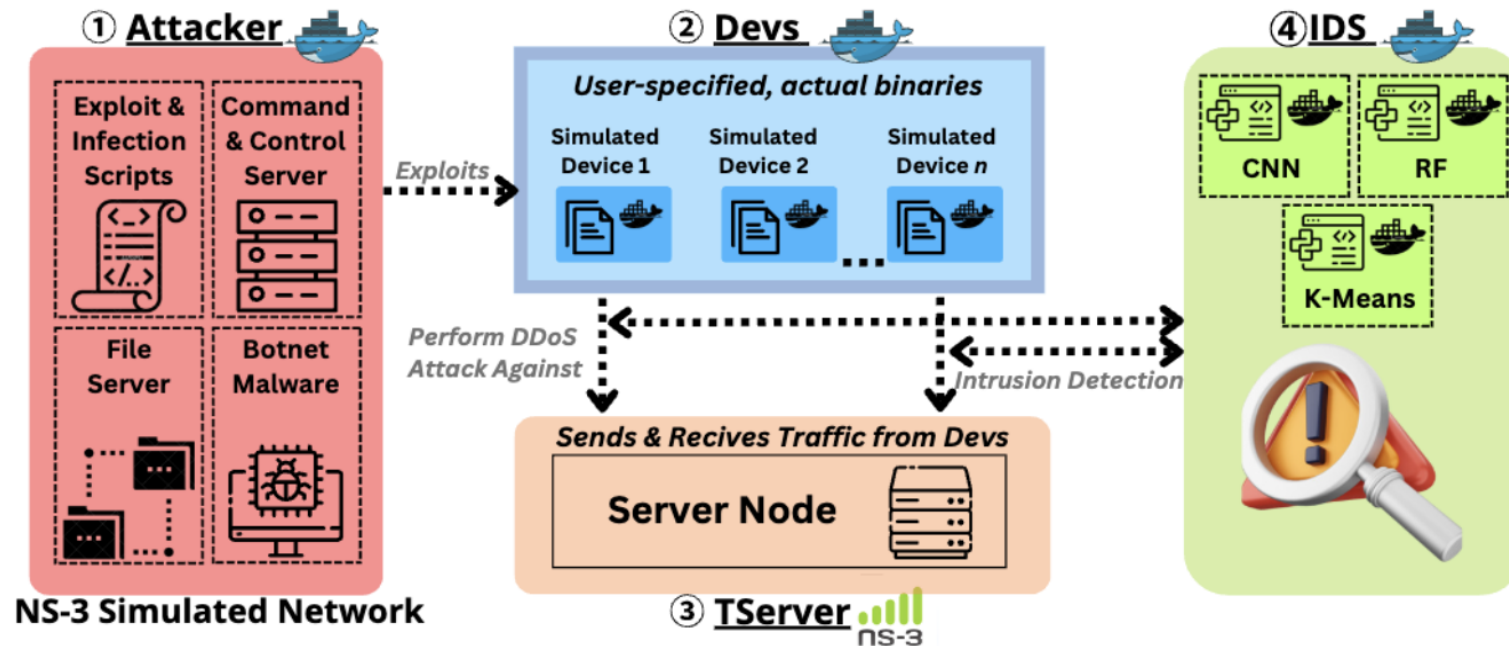
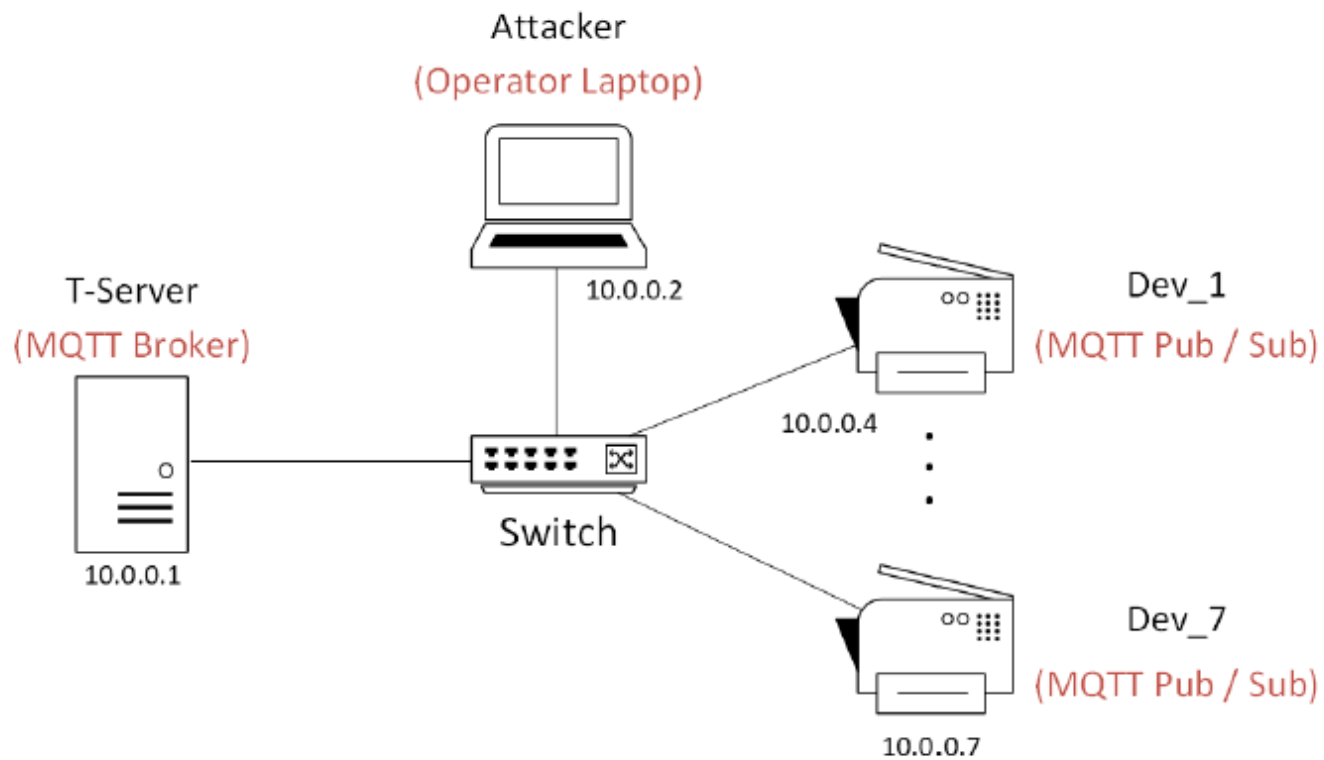


Fig. 1. DDoSHIELD-IoT Overview

DDoShield-IoT e topologia effettiva



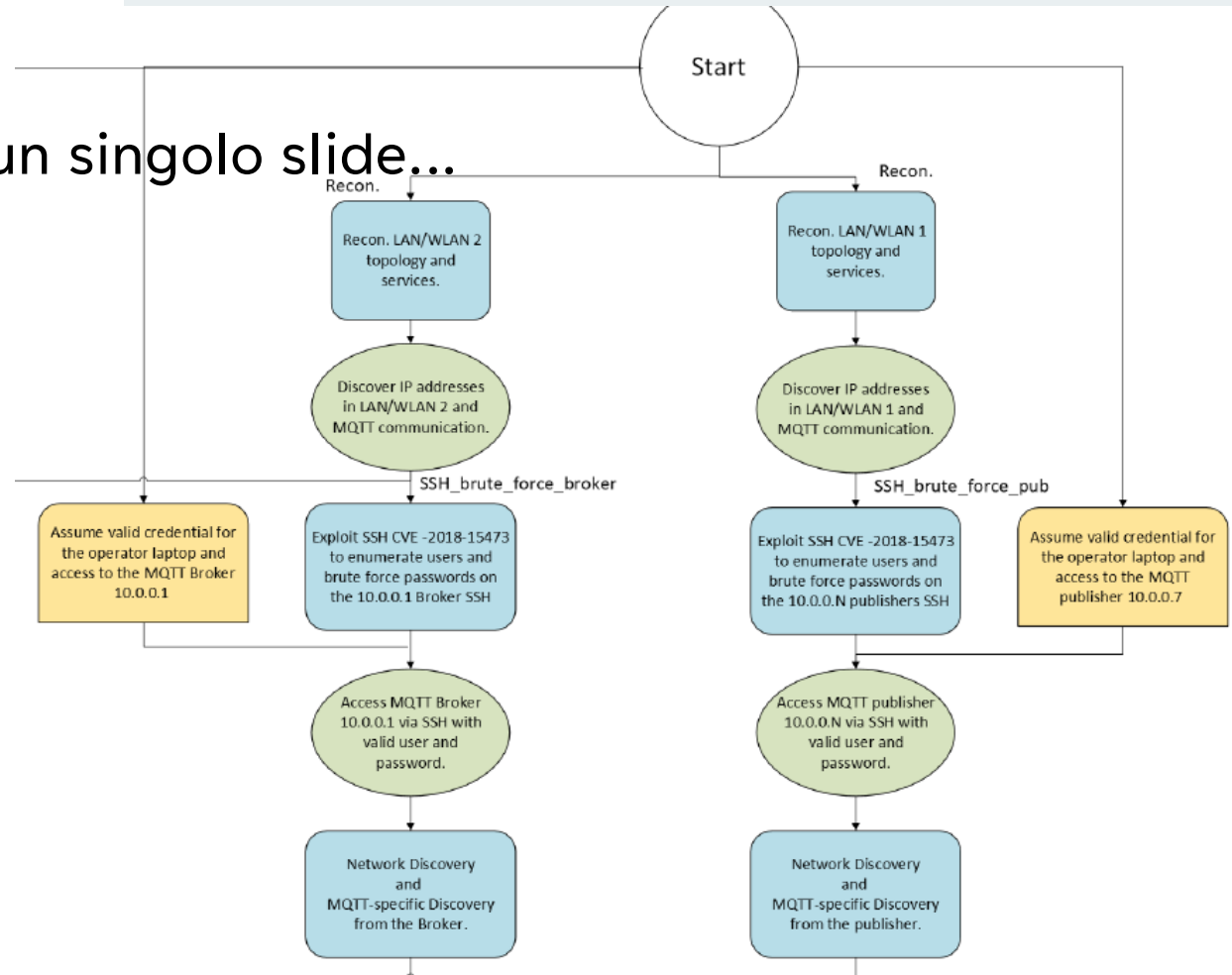
Definizione percorsi d'attacco

- Individuazione componenti principali soggetti ad attacchi
- Individuazione vulnerabilità componenti
- Definizione degli step principali per gli attacchi
- Organizzazione degli attacchi secondo le specifiche di MITRE ATT&CK e delle vulnerabilità secondo CVE



Mappa completa dei percorsi d'attacco

Purtroppo troppo grossa da inserire in un singolo slide...



Esempio definizione percorso secondo MITRE

1. TA0043 - Reconnaissance

- a. T1595.001 - Active Scanning: Scanning IP blocks
- b. T1592 - Gather Victim Host Information
- c. T1589 - Gather Victim Identity Information
- d. T1590 - Gather Victim Network Information
- e. T1598 - Phishing For Information

In the Reconnaissance phase, the attackers can use various methods to gather useful information, like actively scanning the victim's network or more indirect methods like spear phishing.

2. TA0108 - Initial Access

- a. T0866 - Exploit of Remote Services
- b. T1078 - Valid Accounts

1. TA0102 - Discovery

- a. T1046 - Network Service Discovery
- b. T01083 - File and Directory Discovery



Esempio definizione percorso

1. TA0002 - Execution

a. T1059.006 Command and Scripting Interpreter: Python

The attackers run the modified MQTT publisher scripts to start exploiting the CVE-2023-5632 vulnerability and begin the DDoS attack.

2. TA0003 - Persistence

a. T1078.001 -Valid Accounts: Default Accounts

The attackers maintain access to the publishers using existing accounts.

3. TA0040 - Impact

a. T0828 - Loss of Productivity and Revenue

The broker is a victim of a DDoS attack, consuming more bandwidth and requiring more computational power.

Esempio di implementazione

```
import mqtt_utilities as util
import paho.mqtt.client as mqtt
import time
import random

duration = 20
username = "client2"
password = "pass2"
reconnect_delay = random.randint(a: 1, b: 30)
connection = util.Connection_status()
start_time = time.time()
end_of_exec = False

while True:

    if end_of_exec:
        print("script ended")
        break

    client = mqtt.Client(
        mqtt.CallbackAPIVersion.VERSION2, userdata=connection)
    client.username_pw_set(username, password)
    client.on_connect = util.on_connect
    client.on_disconnect = util.on_disconnect
    client.on_publish = util.on_publish
```

```
if util.connect_client(client, connection, reconnect_delay):
    while connection.connected:
        time.sleep(random.randint(a: 1, b: 2))
        elapsed_time = time.time() - start_time
        print("Execution time: " + str(elapsed_time))
        if elapsed_time >= duration:
            print("Time elapsed")
            client.disconnect()
            end_of_exec = True
            break
else:
    elapsed_time = time.time() - start_time
    print("Execution time: " + str(elapsed_time))
    if elapsed_time >= duration:
        print("time elapsed")
        break
    print(f"Resetting client and retrying connection in {reconnect_delay} seconds...", flush=True)
    time.sleep(reconnect_delay)
```



Per altre implementazioni vedere codice

Altrimenti troppe slides per far centrare tutte le immagini...

```
def ssh_brute_force(target_every_machines=False): 1 usage
    with open('log_file.txt', 'a') as log:
        log.write('\nnew session\n')

    # we explore the topology of the network using nmap's ping scan option

    host_settings = "192.168.1.0/24;192.168.0.0/24;10.0.0.0/24"
    host_settings_list = host_settings.split(';')
    outs = [[""]] * 3

    # using the nmap library we can run nmap commands on python
    nmp = nmap.PortScanner()
    print('running host discovery...')
    # we scan the network with the given host settings to find the possible target
    for i in range(3):
        print('host settings: ' + host_settings_list[i])
        # we do a host discovery with the given options
        nmp.scan(hosts=host_settings_list[i], arguments='-T5 -sP')
        # we add the host's ip to 'result' if it's connected to the network
        result = [x for x in nmp.all_hosts() if nmp[x] and nmp[x]['status']['state'] == 'up']
        print('results:')
        # we print the hosts we found and record them to the log file
        if result:
```

Grazie per l'attenzione!

Thank You!